SIMATS ENGINEERING

SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE:ITA14 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.

Code of Conduct:

I S.Harshini(192526064) *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution

Name: S. Harshini
Reg No: 192526008 4

1) No, I would not exploit the vulnerability without obtaining additional written authorization. Even though the company has hired me to perform penetration testing, the one-line email does not clearly define the scope, permitted activities or systems that can be tested.

Ethical hacking principles involved:

1) Proper authorization:
An ethical hacker must obtain clear permission before testing any system.

2) Defined scope:
The testing scope should specify the target systems, permitted techniques, testing period, and limitation.

3) Do no harm:
Exploiting an unknown system may cause data loss, service disruption or unauthorized access

4) Professional responsibility:
An ethical hacker must act honestly, responsibly, and within the agreed rules.

5) Responsible disclosure:
The discovered vulnerability should be reported securely to the authorized company representative.

Steps I would follow:

Stop testing the newly discovered vulnerability

Record the basic details of the vulnerability without exploiting it.

Inform the authorized company representative about the finding.

Request written permission and an updated scope before conducting futher tests.

Continue testing only after receiving proper authorization.

Conclusion:

An ethical hacker must never assume that permission to test one system also permits testing another. Written authorization and a clearly defined scope are essential for conducting safe and legal penetration testing.

2) When I discover that the production database contains real customer financial information, I must prioritize customer privacy, data protection, and the availability of the system. I would avoid accessing, modifying, or extracting sensitive customer records.

Establish rules of engagement and prohibited activities.
Arrange suitable backups and recovery plans
Agree on emergency contacts and incident-response procedures.
Define confidentiality, data-handling, retention and deletion requirements.
Prefer a test database containing dummy customer information.

Conclusion:

Ethical penetration testing aims to identify security weakness without harming customer or business operations.

3) A denial of service (DOS) condition occurs when a system becomes unavailable or unable to provide normal services. During penetration testing, this may happen when testing activities overload a server or consume too many resources.

Preventive measures:

Understand the target:

Identify critical production system and their limitation before testing

Define the scope:

Establish which systems may be tested and which activities are prohibited.

Steps to proceed safely:

1) Stop before accessing sensitive data:

Avoid running SQL infection tests that could expose or modify real customer information

2) Inform the client:

Notify the authorized contact about the vulnerability and the presence of sensitive financial data.

3) Use a safe proof of concept:

Where authorized, use a harmless test query or a dedicated test query or a dedicated test query record to demonstrate the vulnerability without accessing real customer records.

4) Use a test environment:

If possible, reproduce the issue in a staging environment containing dummy data.

5) Minimize data exposure:

Do not download, copy or store customer financial information. Record only the minimum evidence needed

6) Follow the agreed procedure:

Resume testing only after confirming the permitted approach with the client.

Precautions before the engage

Obtain written authorization and clearly define the testing scope.

Identify production systems and senstive database before testing begins.

Avoid risky tests:

Do not perform potentially disruptive tests against live system without explicit authorization and suitable safeguards.

Use controlled environment

Test potentially harmful techniques in a staging environment whenever possible.

Set testing limits:

Agree on rate limits, testing windows, monitoring and stop conditions.

Responsibilities after the outage:

Immediately stop the testing activity that caused the disruption.

Notify the client's designated emergency contact and relevant operations team

Provide accurate information about the activity performed and the observed impact.

Cooperate with the client's incident-response team to restore service safely.

4) When a client asks me to test their security team's detection capability without informing the IT department, I must consider ethical and pratical risks. Even if the intention is to improve security, testing without proper authorization can cause problems.

Ethical Risks:

Lack of authorization:

Testing without approval may violate organizational policies and legal requirements.

Loss of Trust:

The IT team may misunderstand the test as a real cyberattack.

Privacy issues

Confidential customer or employee information may be exposed.

Professional responsibility:

Ethical hackers must follow honesty, confidentiality and accountability

Pratical Risks:

Testing may affect normal operation or cause downtime

False alarms:

Security system may raise unnecessary alerts

Data loss.

Improper testing may damage files or configurations

Incident confusion:

The IT team may waste time responding to a stimulated attack

recautions:

I would obtain written permission from management, define the testing scope, use controlled stimulations, establish emergency contacts and document all activities. If the test must remain a suprize to the IT team, management must still approve it in advance.

Conclusion:

Ethical hacking must always follow authorization and professional guidelines. Proper planning helps evaluate security capabilites without hoarming the organization.

5) A red team exercise and a vulnerability assessment are important cybersecurity techniques. Both improve security, but they have different objectives and methods.

1) Red Team Exercise:

A red team exercise stimulates real-world cyber attacks to evaluate an organization's ability to prevent, detect, and respond to threats.

Approach:

Obtain written authorization and define the scope.
Stimulate approved attack scenarios
Evaluate the security team's detection and response
Prepare a report suggesting improvements

Example:

A bank conducts an authorized stimulation to check whether its security team detects suspicious activity in a tests environments.

Vulnerability Assessment:

A vulnerability assessment identifies and prioritizes weakness in systems, networks, and application before attackers can exploit them.

Approach:

Obtain permission to examine specified system
Use approved tools to identify security weaknesses
Classify vulnerabilies according to severity.
Recommend solutions to fix the identifies issues.

Example: Recommend solution to fix issues. A bank scans its test servers and discovers outdated software and weak configurations, which are then connected.

Ethical Considerations:

Both activities require authorization, confidentiality, and clear testing boundaries. Testing must avoid unnecessary disruption, protect sensitive information, and report findings resport responsibly.

Conclusion:

A red team exercise tests how effectively an organization responds to stimulated attacks, while a vulnerability assessment identifies weakness that need corrections